

OSTBAYERISCHE
TECHNISCHE HOCHSCHULE
REGENSBURG

DITS Report

Tapo P100 TP-link

Mini Smart Wi-Fi Socket

Thi Thu Thao Nguyen

Matriculation Number: 3536854

Contents

1. Device Description – Tapo P100 Smart Wi-Fi Plug 3

1. 1. Brief Description 3

1.2. Operation Principle 3

1.3. Technical Details 3

1.4. Known Vulnerabilities 4

2. Setup of the device / user account 5

3. Connections (BT / Wi-Fi / Zigbee / Other) 6

3.1. Connections and encryption 6

3.2. Nmap scan for open ports 7

3.3. Telnet/SSH/Web GUI connection via open port 80 9

4. Vulnerabilities / Security 10

4.1. Hardcoded credentials for TP-Link Tapo Android application 10

4.2. Writeable Generic Attribute Profile (GATT) 10

4.3. Onboarding attack surface 11

4.4. Dependence on Cloud services 12

5. Investigation of vulnerabilities 13

5.1. Ghidra analysis 13

5.2. nRF connect scanning 14

5.3. IEEE 802.11 Wi-Fi Frames Captured Using Wireshark 14

5.4. Attempt to capture UDP package using Wireshark 16

5.5. To be inspected further 16

6. Evaluation 18

7. Lessons learned for the secure development of IoT devices 19

References 20

Appendices 22

Hostapd configuration 22

DHCP configuration 22

1. Device Description – Tapo P100 Smart Wi-Fi Plug

1. 1. Brief Description

The Tapo P100 is a smart Wi-Fi plug of TP-Link Systems Inc that enables remote control of electrical appliances via a mobile application. Users can switch devices on or off, set schedules, and manage basic automation.(*Tapo P100 | Mini Smart Wi-Fi Socket | Tapo*, n.d.)

1.2. Operation Principle

The device connects to a 2.4 GHz Wi-Fi network and communicates through Tapo cloud. User commands are sent from the mobile app to the cloud and then forwarded to the device.

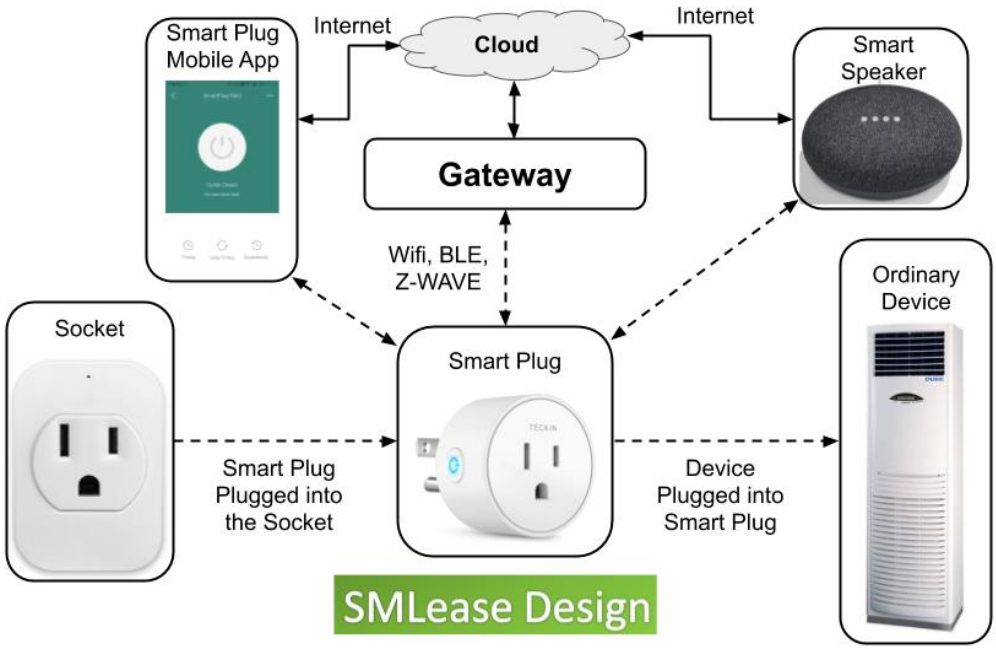
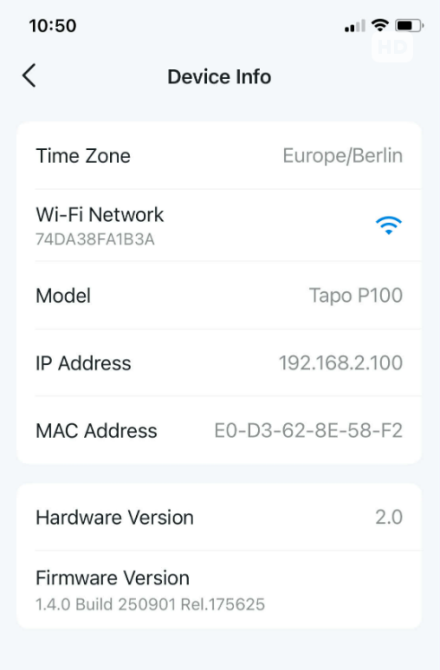


Figure 1. Smart Plug communication (Lynch, 2023)

1.3. Technical Details



Connectivity: Wi-Fi IEEE 802.11 b/g/n (2.4 GHz)

Hardware version: 2.0

Power: AC 220–240 V, internal relay-based switching

Firmware: 1.4.0 Build 250901 Rel.175625

Firmware updates are delivered over-the-air via the cloud. TP-Link does not publish a guaranteed update lifetime for the Tapo P100.

Latest App: Tapo App (iOS / Android) version 3.15.118

Manufacturer: TP-link

Security contact: https://www.tp-link.com/en/support/security/

Figure 2. Device Info in Tapo App

1.4. Known Vulnerabilities

Common Vulnerabilities and Exposures (CVE) database has shown vulnerabilities of TPLink devices, including smart bulbs, smart cameras, as well as Tapo Plug P100. The reported CVEs reveal insecurities in the authentication, encryption, and access control mechanisms implemented within both the firmware of Tapo IoT devices and the mobile application. Several vulnerabilities allow remote attackers to obtain sensitive information, replay encrypted messages, or access user credentials in plaintext without proper authorization.

However, for Tapo P100, the vulnerabilities are of older firmware and application and have since been addressed by TP-Link in the later versions.

CVE-2023-38906

An issue in TPLink Smart Bulb Tapo series L530 1.1.9, L510E 1.0.8, L630 1.0.3, P100 1.4.9, Smart Camera Tapo series C200 1.1.18, and Tapo Application 2.8.14 allows a remote attacker to obtain sensitive information via the authentication code for the UDP message.

CVE-2023-38907

An issue in TPLink Smart Bulb Tapo series L530 before 1.2.4, L510E before 1.1.0, L630 before 1.0.4, P100 before 1.5.0, and Tapo Application 2.8.14 allows a remote attacker to replay old messages encrypted with a still valid session key.

CVE-2023-38908

An issue in TPLink Smart Bulb Tapo series L530 before 1.2.4, L510E before 1.1.0, L630 before 1.0.4, P100 before 1.5.0, and Tapo Application 2.8.14 allows a remote attacker to obtain sensitive information via the TSKEP authentication function.

CVE-2023-38909

An issue in TPLink Smart Bulb Tapo series L530 before 1.2.4, L510E before 1.1.0, L630 before 1.0.4, P100 before 1.5.0, and Tapo Application 2.8.14 allows a remote attacker to obtain sensitive information via the IV component in the AES128-CBC function.

CVE-2023-34829

Incorrect access control in TP-Link Tapo before v3.1.315 allows attackers to access user credentials in plaintext.

CVE-2023-27098

TP-Link Tapo APK up to v2.12.703 uses hardcoded credentials for access to the login panel.

2. Setup of the device / user account

Device is configured using the TP-Link Tapo mobile application (android/IoS) and requires a cloud-based user account.

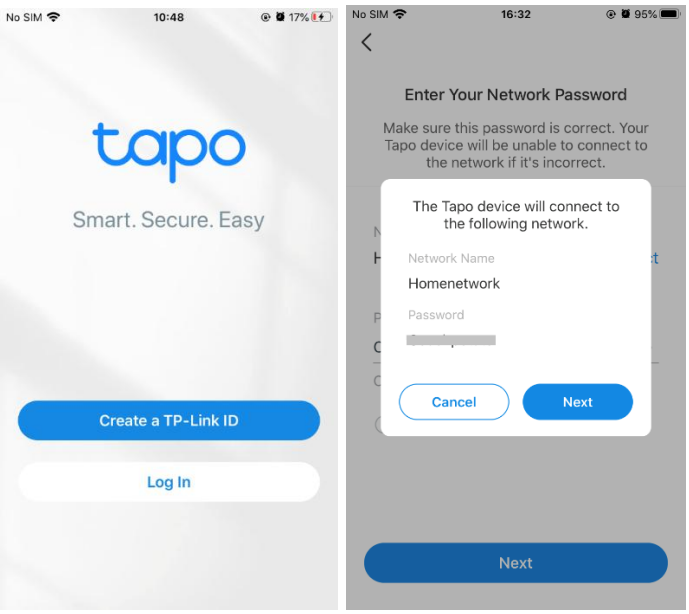


Figure 3. Tapo Setup (*How to Set up the Tapo Smart Plug | TP-Link Germany*, n.d.)

After inserting Tapo plug into a socket and its LED blinking orange and green, Tapo P100 is ready for pairing mode. Bluetooth is used for device discovery and onboarding.

Regarding WLAN Credential Transfer, The Wi-Fi password is transmitted to the device via the app to establish network connectivity.

For the main communication, device uses cloud-based for management and authentication.

(*How to Set up the Tapo Smart Plug | TP-Link Germany*, n.d.)

3. Connections (BT / Wi-Fi / Zigbee / Other)

3.1. Connections and encryption

- Wi-Fi

The Tapo P100 connects to the local network via wifi 2.4 GHz (IEEE 802.11 b/g/n).

It joins the WLAN using credentials provided during setup via the Tapo mobile application.

- Bluetooth

Tapo uses Bluetooth only when initially onboarding. It enables device discovery and provisioning of Wi-Fi credentials. After successful setup, Bluetooth is no longer used for regular operation or device control.

No additional physical or wireless interfaces are available.

- Encryption

Wi-Fi encryption: WPA2-PSK (dependent on router configuration)

Cloud communication: Encrypted using HTTPS / TLS

This shows that sensitive information is protected while in transit, such as commands and authentication tokens.

Tapo make connections with TP-Link Tapo cloud servers for

- ✓ Remote control via the mobile app
- ✓ Device status synchronization
- ✓ Firmware updates

The device depends strongly on cloud services due to the limited direct local-only control without cloud involvement.

3.2. Nmap scan for open ports

```
nmap -sn 192.168.2.0/24
```

```
Starting Nmap 7.98 ( https://nmap.org ) at 2025-12-30 22:32 +0100
Nmap scan report for 192.168.2.1
Host is up (0.017s latency).
MAC Address: 74:DA:38:FA:AB:8F (Edimax Technology)
Nmap scan report for 192.168.2.102
Host is up (0.27s latency).
MAC Address: 72:AA:D6:A5:06:1B (Unknown)
Nmap scan report for 192.168.2.104
Host is up (0.25s latency).
MAC Address: E0:D3:62:8E:58:F2 (TP-Link Systems)
Nmap scan report for 192.168.2.101
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 16.90 seconds
```

Figure 4. WLAN IP scanning

Since the wifi router has changed during the implementation of this project, the IP of Tapo plug is 192.168.2.100 in the first phase and 192.168.2.104 in the later phase.

nmap -sS 192.168.2.104

```
Nmap scan report for 192.168.2.100
Host is up (0.012s latency).
Not shown: 999 closed tcp ports (reset)
PORT   STATE SERVICE    VERSION
80/tcp open  tcpwrapped
MAC Address: E0:D3:62:8E:58:F2 (TP-Link Systems)
```

Figure 5. Tapo Plug TCP scanning

An Nmap TCP and UDP scanning shows that TCP port 80 is open. TCP port 80 in Tapo is used for an internal HTTP-based service. This service is mainly accessed by the Tapo mobile application and may expose internal APIs rather than a graphical web UI.

Regarding security, TCP port 80 open indicates a local attack surface. Though the risk might be limited, an examination is implemented in the chapter 3.3

nmap -sU 192.168.2.104

```
Nmap scan report for 192.168.2.104
Host is up (0.0100s latency).
All 1000 scanned ports on 192.168.2.104 are in ignored states.
Not shown: 1000 closed udp ports (port-unreach)
MAC Address: E0:D3:62:8E:58:F2 (TP-Link Systems)
```

Figure 6. Tapo Plug UDP scanning

No UDP ports were identified as open. This does not mean that all the ports are close. It might due to the fact that UDP ports only responds to solicited probes.

Attempts have been made to seek for UDP open ports by using Wireshark with monitor mode from a wifi adapter. But it failed to capture UDP open ports as it was in wifi 802.11 layer. (see Figure 11).

3.3. Telnet/SSH/Web GUI connection via open port 80

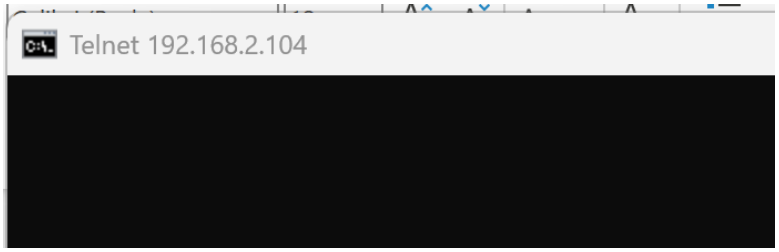
- SSH

```
C:\Users\PC>ssh 192.168.2.104 -p 80
Connection closed by 192.168.2.104 port 80
```

Although TCP port 80 is open on the Tapo P100 device, it does not provide an SSH administrative interface. Connection attempts using SSH are immediately rejected, indicating that the port is restricted to internal communication only.

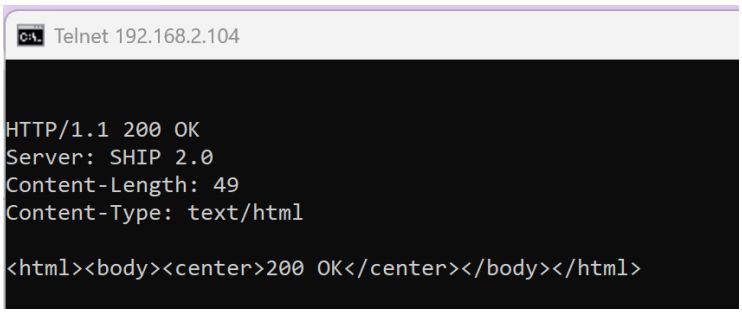
- Telnet

telnet 192.168.2.104 80



Telnet connection attempts to the Tapo P100 device did not return any login prompt or service banner, indicating that no Telnet service or local administrative interface is exposed. This behavior reduces the device's network attack surface.

- Web GUI



An HTTP service was observed on TCP port 80, responding with a minimal “200 OK” message and a proprietary server identifier (“SHIP 2.0”). No web-based administrative interface or authentication mechanism was exposed. The service appears to be limited to internal status or provisioning functionality, thereby minimizing the device’s web attack surface.

4. Vulnerabilities / Security

4.1. Hardcoded credentials for TP-Link Tapo Android application

As reported in CVE-2023-27098, the TP-Link Tapo Android application (up to version 2.12.703) contains hardcoded credentials within the client-side code.

A version tp-link-tapo-2-8-20 APK (Android Package Kit) was downloaded from APKMirror. Static analysis using Ghidra on the version revealed hardcoded credentials in the application. The default credentials identified were a static username and password used to access an internal login. (see Figure 8, 9, 10 in chapter 5.1)

The presence of hardcoded credentials in a client application significantly weakens the security model, as attackers can extract these values through reverse engineering and gain unauthorized access to the Tapo as well as extracting the WLAN credential and attack other devices in the Tapo ecosystem.

4.2. Writeable Generic Attribute Profile (GATT)

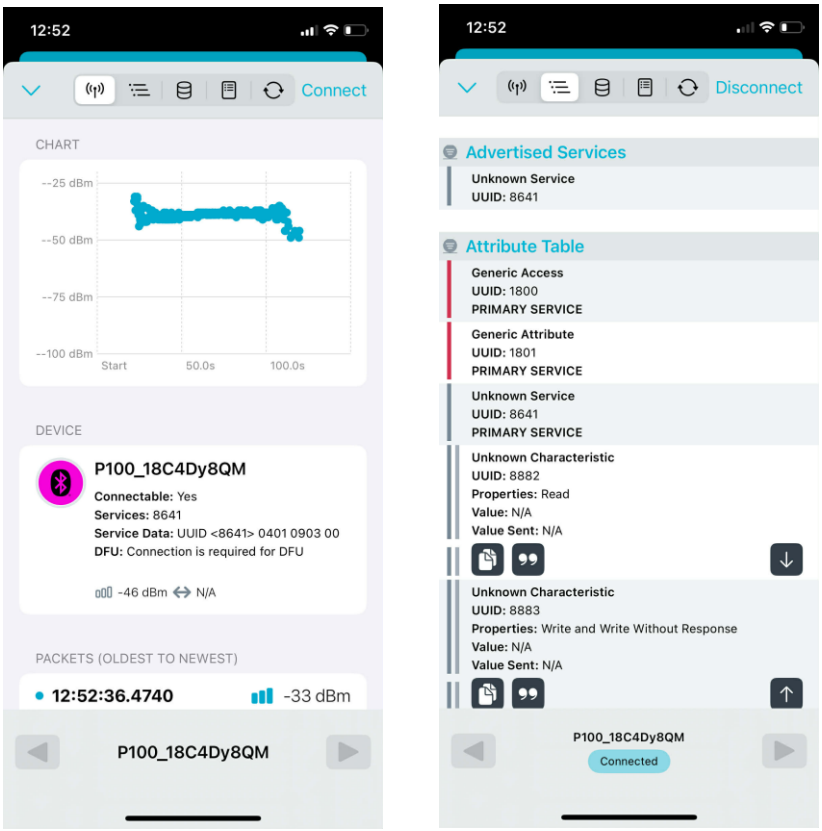
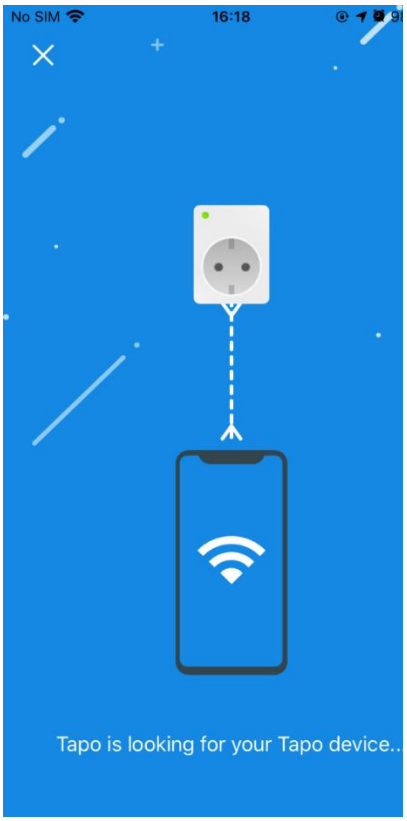


Figure 7. BLE scanning process using nRF Connect during the initial setup of the Tapo smart plug.

During the onboarding process, Tapo exposed the presence of a vendor-specific GATT characteristic (UUID: 0x8883) that shows write permissions. This characteristic represents a potential attack surface, particularly with insufficient authentication and authorization. (*Generic Attribute Profile (GATT) — BLE-Stack User's Guide for Bluetooth 4.2 3.01.01.00 Documentation*, n.d.)

Although attempts to write data to this characteristic during testing did not affect the normal operation of the Tapo device, it remains a security risk. Should future firmware updates introduce functional write logic or insufficient validation, this characteristic could be exploited by an attacker with BLE Man-in-the-Middle (MITM) attacks, Replay attacks during the onboarding process, Firmware downgrade or unauthorized firmware manipulation.

4.3. Onboarding attack surface



The Tapo P100 does not support a local device account and does not provide username/password credentials for direct login. All authentication and authorization are handled via the TP-Link Cloud account.

Bluetooth is used only during the initial onboarding process for device discovery and provisioning. During this phase, a nearby attacker could theoretically detect and attempt to onboard an unconfigured or factory-reset device, as no pairing password is required.

The attacker can then successfully complete the onboarding process and binding the device to a valid TP-link Cloud account.

However, the exposure is limited as it exists only during a short and specific phase of the onboarding process. Once the device has been successfully configured and bound to a TP-Link Cloud account, the onboarding mode is disabled and cannot be reused without physical interaction.

Additionally, exploitation requires physical proximity and precise timing. An attacker must be close to the device and attempt onboarding before the legitimate user completes the setup. This significantly reduces the likelihood of a successful attack compared to remotely exploitable vulnerabilities.

4.4. Dependence on Cloud services

When the Tapo devices depends heavily on cloud, potential vulnerabilities emerge. Attackers might find extensive exploited surface including Cloud APIs and authentication services. Once the cloud account is compromised, attackers can control all devices in the ecosystem. In addition, user credentials, device identifiers, and authentication tokens which are processed in the cloud may be exposed through breaches or weak access control.

5. Investigation of vulnerabilities

5.1. Ghidra analysis

An APK of tp-link-tapo-2-8-20 was downloaded from APKMirror to test the hardcoded credentials vulnerabilities. (“TP-Link Tapo 2.8.20 (Arm64-V8a + Arm-V7a) (Nodpi) (Android 5.0+) APK Download by TP-LINK SYSTEMS INC.,” n.d.)

From the Ghidra analysis, after searching for some strings like “username” and “password”, “pwd”, the sensitive information shows as in the following figures.

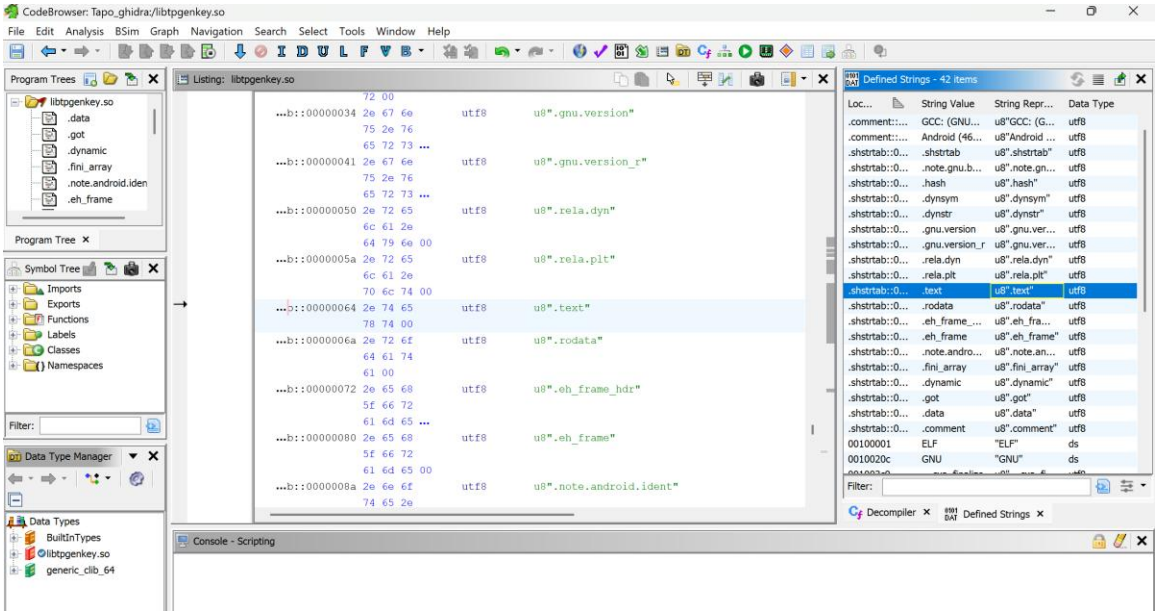


Figure 8. Ghidra analysis on TP-link Tapo 2-8-20 APK

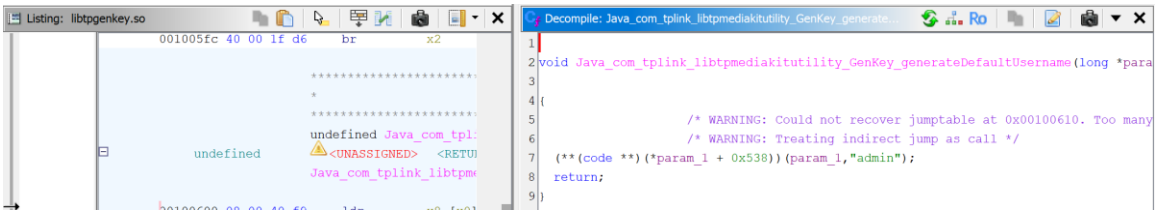


Figure 9. Ghidra analysis shows Default Username: “admin”

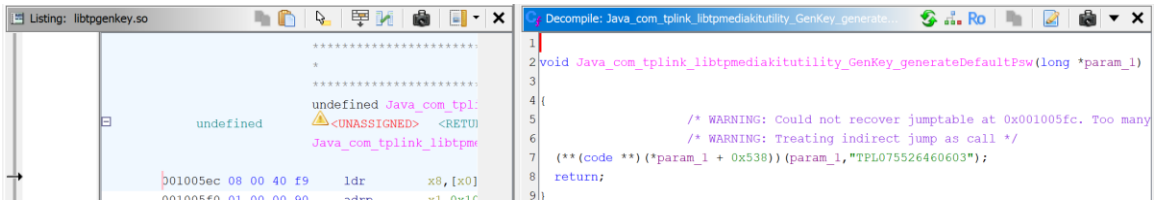


Figure 10. Ghidra analysis shows Default password: "TPL075526460603"

This demonstrates a high vulnerability since the attacker once obtains the application can access WLAN credentials as well as takes control of the device. The attackers are able to attack other devices in the WLAN which poses a risk to the security and stability of the entire network.

5.2. nRF connect scanning

As shown in Figure 7, during the onboarding process, the Tapo device communicates with the mobile application via Bluetooth Low Energy (BLE). An nRF-based sniffer was used to observe BLE advertising packets, enumerate the device's GATT services, and inspect characteristic properties during the onboarding process.

The process includes setting up Tapo, make sure that nRF Connect device nearby Tapo, activate BLE scanning during the setup, Browse the device's GATT services and characteristics and Inspect Characteristic Properties

The analysis revealed the presence of a vendor-specific GATT characteristic (UUID: 0x8883) that exposes write permissions.

5.3. IEEE 802.11 Wi-Fi Frames Captured Using Wireshark

To be able to capture Wifi communication between Tapo Plug and Router before forwarding the traffic to cloud, Bryan Bakwowi (IoTS classmate) and I used monitor mode from Alfa wifi adapter to sniff the package. In figure 11 below, it shows that the data transferred is encrypted, which hinder attackers from cracking it.

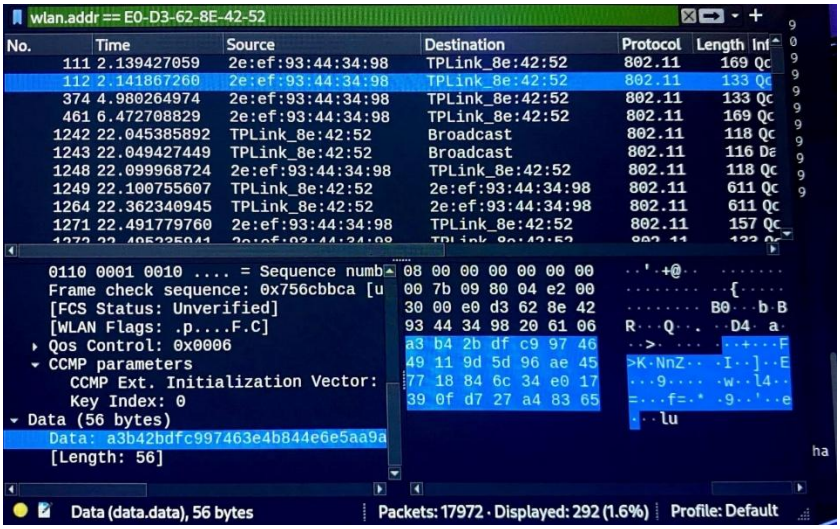


Figure 11. Captured IEEE 802.11 data frames exchanged between the wireless router and TP-Link Tapo via monitor mode

- ❖ The monitor mode setting up includes:

Verify that the adapter

```
ip link
```

Stop network managers

```
sudo systemctl stop NetworkManager
sudo systemctl stop wpa_supplicant
```

Enable monitor mode

```
sudo airmon-ng check kill
sudo airmon-ng start wlan0
```

5.4. Attempt to capture UDP package using Wireshark

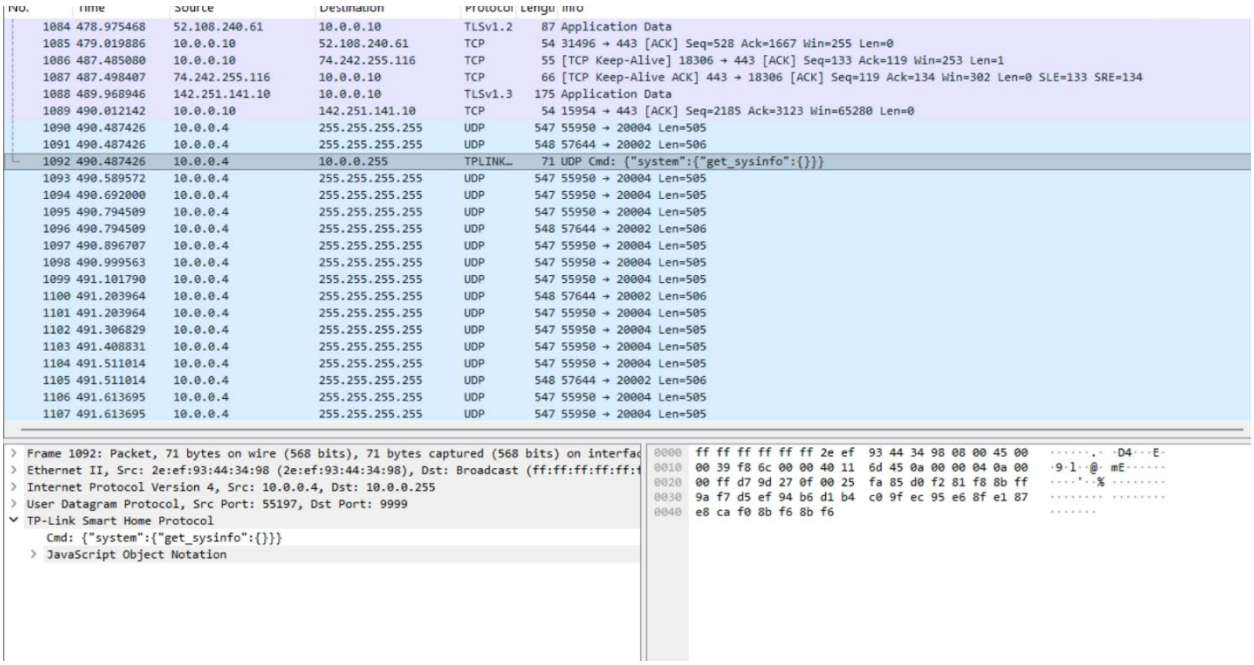


Figure 12: Captured network traffic showing data exchange between TP-Link Tapo mobile app and WLAN via UDP broadcast messages. The packets are sent to the broadcast address (255.255.255.255).

It did not succeed when capturing the UDP packages when Tapo plug was onboarding. Instead it saw an UDP broadcasting package sent from Tapo mobile App to the whole WLAN asking for the system information of Tapo Plug. This package is, therefore, not vulnerable as it is just a query, not the response from Tapo Plug.

5.5. To be inspected further

Given the fact that monitor mode with Wireshark could not catch UDP package, a Man-in-the-Middle might be a better approach to inspect UDP authentication communication as well as other communication within Tapo, router and cloud, and Tapo app.

Architecture of the MiTM attack as follows.

- A Linux laptop was configured to operate as a wireless Access Point.
- The Tapo smart plug and the mobile phone were connected to this access point.
- All network traffic was routed through the laptop's network interface.
- The transmitted traffic could be captured and analyzed using Wireshark after WPA2 decryption.

❖ Configuring a wireless Access Point:

Hostapd configuration

```
sudo nano /etc/hostapd/hostapd.conf
```

(Refer to appendice Hostapd configuration for config file)

DHCP configuration

```
sudo nano /etc/dnsmasq.conf
```

(Refer to appendice DHCP configuration file)

Add IP to interface AP

```
sudo ip addr add 192.168.50.1/24 dev wlan0
sudo ip link set wlan0 up
```

Turn on NAT for internet

```
sudo sysctl -w net.ipv4.ip_forward=1
sudo iptables -t nat -A POSTROUTING -o eth0 -j MASQUERADE
sudo iptables -A FORWARD -i wlan0 -o eth0 -j ACCEPT
sudo iptables -A FORWARD -i eth0 -o wlan0 -m state --state RELATED,ESTABLISHED -j ACCEPT
```

Activate AP

```
sudo systemctl stop NetworkManager
```

```
sudo hostapd /etc/hostapd/hostapd.conf
```

Now the newly created Access Point is ready. Tapo plug, Tapo app and laptop are to be accessed to the Access Point. Onboarding process is to be set up as normal. After that, Wireshark is ready to capture packages within the networking and MiTM architecture is completed.

Due to the constrain of the situation in which I do not have a wifi router, and due to the limited time, this analysis is considered but yet to be implemented in the report scope.

6. Evaluation

Overall, Tapo P100 smart plug currently exposes only minimal security vulnerabilities, mainly due to firmware updates and the use of encrypted communication protocols over time, particularly through the remediation of previously reported CVEs.

The issue of hardcoded credentials in the Tapo Android application (versions up to v2.12.703) has been addressed in later releases. Consequently, the risk of attackers gaining access to the application and exploiting the local WLAN environment has been significantly reduced.

Tapo plug also revealed very few open ports, none of which are directly exploitable, thereby limiting the device's exposed attack surface.

Although writing GATT are enabled during the onboarding phase, this functionality is constrained and does not pose a significant security threat to the device.

For Wi-Fi communication, data frame exchanged between the Tapo plug and the router were observed to be encrypted via Wireshark analysis. As a result, only limited security risks are exposed at this stage. The potential vulnerability of UDP packages is yet to be evaluated due to the lack of the components. It is supposed to be captured through a Man-in-The-Middle implementation. The access to cloud's data is yet to be examined too due to the advance scope and server-side nature.

During the onboarding of Tapo plug, though there is a risk that attackers can be close to the device and take attempts to control the device, this risk is minimal due to the required physical proximity and precise timing.

7. Lessons learned for the secure development of IoT devices

The security assessment of the Tapo P100 smart plug highlights several important lessons regarding the design and operation of consumer IoT devices. Secure default configurations play a crucial role in limiting the attack surface, especially in these days where attackers can use tools to crack weak credential easily. (Pereira, 2025)

The analysis also shows that the loss of cloud account credentials can affect more than just the device itself. Because the Tapo P100 communicates with cloud services and operates inside the local WLAN, compromised credentials could allow an attacker to control the device or use it as a starting point for further attacks within the network. (*Most Common Threats to Security and Privacy of IoT Devices*, 22:58:45+00:00)

Strong authentication is especially important during security-critical phases such as onboarding. Although only WLAN is used during setup, valid cloud authentication reduces the risk of physical proximity attacks.

Encrypted communication is a key protective measure. Network traffic exchanged between the IoT device, the router, and external services is encrypted, preventing meaningful inspection through passive packet capture. This limits the risk of eavesdropping, data leakage, and manipulation at the network level under normal operating conditions.

IoT devices which have minimal number of open ports is potentially less vulnerable to attackers. It reduces unnecessary interfaces, which is refrain attackers from exploiting.

Finally, ongoing firmware updates and the remediation of reported CVEs from the manufaturers contribute to the long-term security of the device.

References

Generic Attribute Profile (GATT)—BLE-Stack User's Guide for Bluetooth 4.2 3.01.01.00 documentation. (n.d.). Retrieved January 4, 2026, from https://software-dl.ti.com/lprf/sdg-latest/html/ble-stack-3.x/gatt.html

Heaney, P. (2025, May 1). *How To Set Up Wireless Access Point: Easy Setup Guide*. https://wirelessspark.com/how-to-set-up-wireless-access-point/

hostapd Linux documentation page—Linux Wireless documentation. (n.d.). Retrieved January 3, 2026, from https://wireless.docs.kernel.org/en/latest/en/users/documentation/hostapd.html

How to set up the Tapo smart plug | TP-Link Germany. (n.d.). Retrieved December 30, 2025, from https://www.tp-link.com/de/support/faq/2846/?utm_source=chatgpt.com

Lynch, M. (2023, August 2). What Are Smart Plugs and What Do They Do? *The Tech Edvocate*. https://www.thetechedvocate.org/what-are-smart-plugs-and-what-do-they-do/

Most Common Threats to Security and Privacy of IoT Devices. (22:58:45+00:00). GeeksforGeeks. https://www.geeksforgeeks.org/blogs/most-common-threats-to-security-and-privacy-of-iot-devices/

Pereira, C. (2025, September 2). *Good practices in IoT device security: Taking advantage of the lessons that others have learned the hard way*. https://foundries.io/insights/blog/good-practices-iot-device-security/

Tapo P100 | Mini Smart Wi-Fi Socket | Tapo. (n.d.). Retrieved January 3, 2026, from https://www.tapo.com/en/product/smart-plug/tapo-p100/

TP-Link Tapo 2.8.20 (arm64-v8a + arm-v7a) (nodpi) (Android 5.0+) APK Download by TP-LINK SYSTEMS INC. (n.d.). *APKMirror*. Retrieved December 30, 2025, from https://www.apkmirror.com/apk/tp-link-corporation-limited/tp-link-tapo/tp-link-tapo-2-8-20-release/tp-link-tapo-2-8-20-android-apk-download/

Appendices

Hostapd configuration

```
interface=wlan0
driver=nl80211
ssid=Tapo_Test_AP
hw_mode=g
channel=6
ieee80211n=1
wmm_enabled=1
auth_algs=1
wpa=2
wpa_passphrase=12345678
wpa_key_mgmt=WPA-PSK
rsn_pairwise=CCMP
```

(*Hostapd Linux Documentation Page — Linux Wireless Documentation*, n.d.)

DHCP configuration

```
interface=wlan0
dhcp-range=192.168.50.10,192.168.50.100,12h
```

(Heaney, 2025)